COMPTE RENDU – TP 4.1 : pfSense et segmentation réseau

Introduction

L'objectif de ce TP était de transformer un laboratoire où toutes les machines communiquaient librement (réseau Host-Only unique) en une architecture sécurisée, segmentée par un pare-feu pfSense. Les machines Ubuntu et Windows ont été placées dans un réseau interne (LAN), tandis que Kali (attaquant) se trouve sur un réseau externe (WAN). pfSense contrôle tous les flux entre ces deux zones.

1. Architecture mise en place

Zone	Machine	Adresse IP	Passerelle
LAN	Ubuntu	192.168.1.20/24	192.168.1.1
LAN	Windows	192.168.1.20/24	192.168.1.1
LAN	pfSense (LAN)	192.168.1.1	-
WAN	pfSense (WAN)	DHCP (NAT)	-

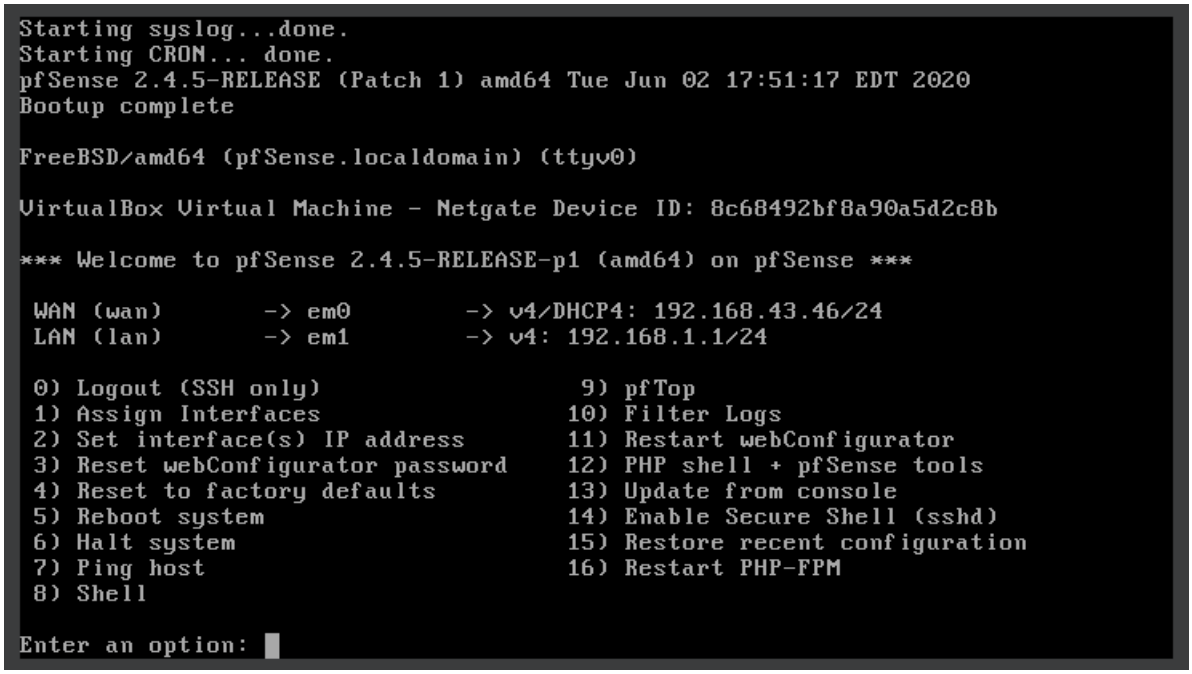
2. Configuration des machines

2.1 pfSense

Interface WAN : NAT (accès Internet)

Interface LAN : Host-Only (192.168.1.1/24)

Accès web : https://192.168.1.1 (admin / pfSense)



2.2 Ubuntu

sudo ip addr add 192.168.1.10/24 dev eth0

sudo ip route add default via 192.168.1.1

2.3 Windows

IP : 192.168.1.20

Masque : 255.255.255.0

Passerelle : 192.168.1.1

3. Tests initiaux – Règle par défaut

Règle par défaut pfSense (avant modification)

Action : Pass (Autoriser)

Protocole : Tous

Source : LAN net

Destination : Tous

Conclusion : Avec la règle par défaut, tout le trafic est autorisé (sortant du LAN). Cela ne protège pas contre un attaquant qui compromettrait une machine interne.

4. Mise en place d'une règle restrictive

Objectif

Autoriser uniquement le HTTP (port 80)

Bloquer tout le reste (ping, HTTPS, scans, etc.)

Règle créée

Paramètre --- Valeur

Action --- Pass

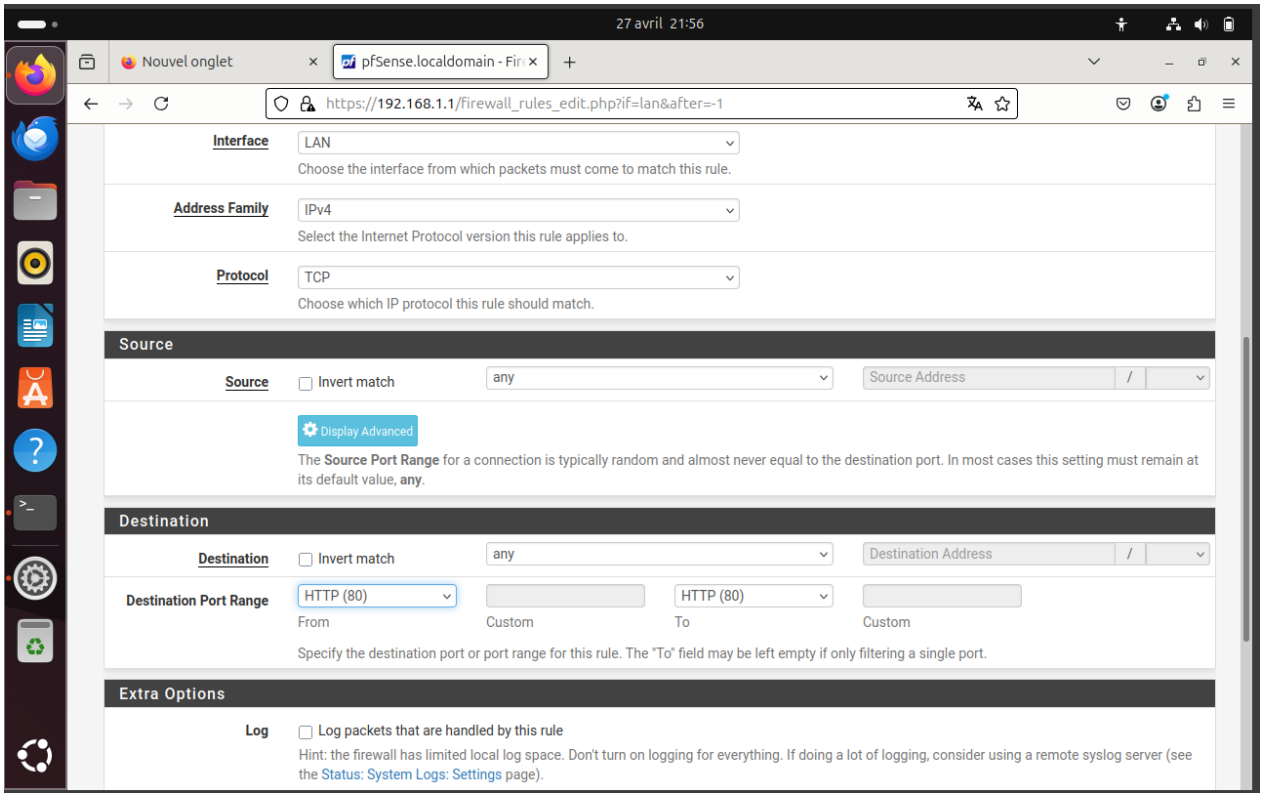
Interface --- LAN

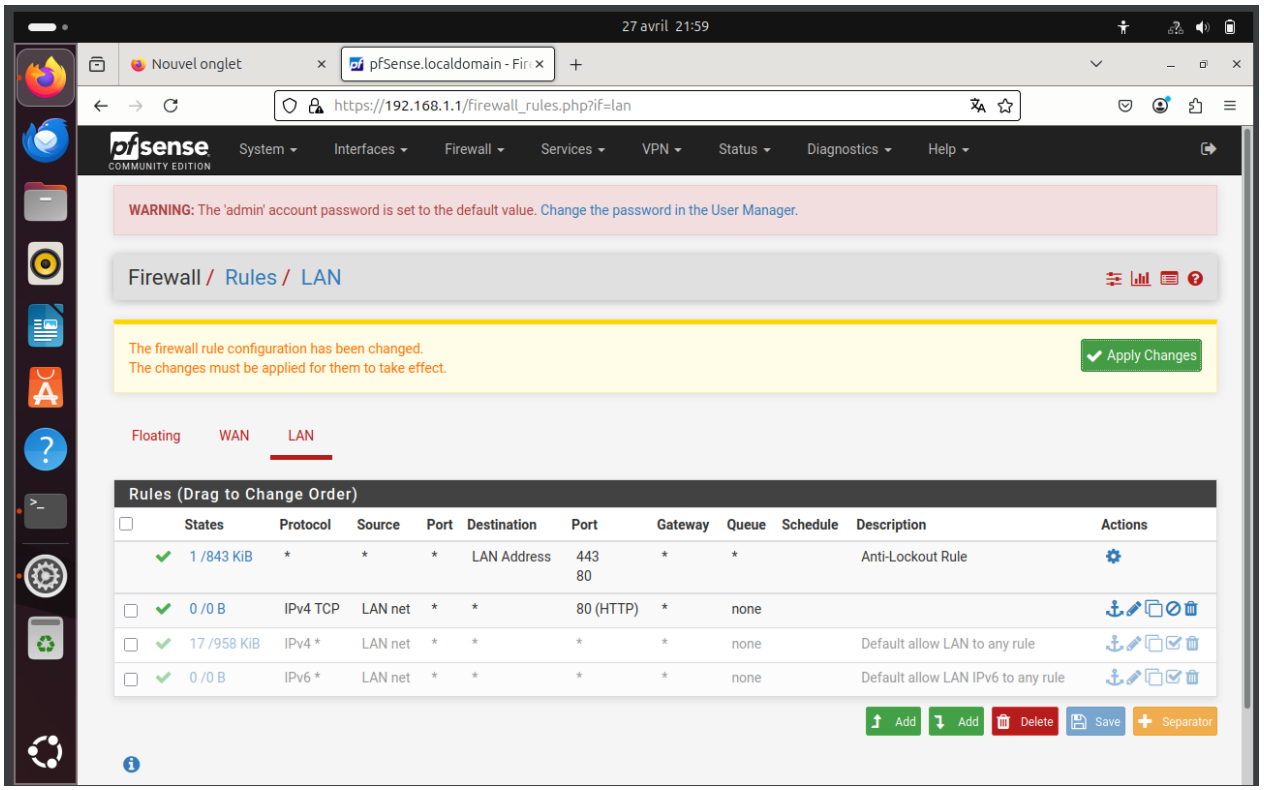
Protocole --- TCP

Source --- any

Destination --- any

Port destination --- HTTP (80)





Règle par défaut désactivée

Les règles par défaut ont été désactivée pour ne laisser passer que ce que nous autorisons explicitement.

Problème constaté avec curl http://8.8.8.8

Lors des premiers tests, la commande :

curl http://8.8.8.8

a échoué avec le message :

curl: (28) Failed t

o connect to 8.8.8.8 port 80 after 134556 ms

Explication technique

8.8.8.8 est un serveur DNS public de Google, pas un serveur web.

Il écoute uniquement sur le port 53 UDP/TCP, pas sur le port 80 HTTP.

N L'échec n'est pas lié au pare-feu, mais à la cible elle-même.

Solution adoptée

Nous avons utilisé une adresse IP qui répond réellement sur le port 80 :

curl http://142.250.185.46

5. Test de scan nmap (depuis Kali)

Conformément à votre déroulement réel :

« nmap a été lancé depuis Kali, car Ubuntu n'avait pas nmap installé et nécessitait des paquets supplémentaires. »

Commande exécutée depuis Kali (connecter au LAN uniquement pour cette commende) vers 8.8.8.8 :

nmap -sS 8.8.8.8

6. Interprétation détaillée

Pourquoi HTTP fonctionne ?

La règle Pass TCP/80 correspond exactement au trafic HTTP.

Pourquoi le Ping échoue ?

ICMP n'est pas autorisé (pas de règle Pass pour ICMP).

Pourquoi le nom de domaine ne résout pas ?

Le DNS (port 53) est bloqué.

En production, on ajouterait une règle DNS autorisée vers un serveur interne.

Pourquoi le scan nmap échoue ?

Seul le port 80 répond. Les autres ports sont filtrés.

Le scan SYN ne peut pas cartographier le réseau correctement.

Conclusion

Ce TP a permis de :

Segmenter un laboratoire avec pF Sensé

Comprendre la différence entre IP fonctionnelle pour HTTP (ex: 142.250.185.46) et IP non web (8.8.8.8)

Constater que le filtrage peut bloquer DNS, rendant nécessaire l'usage d'IP directes

Réaliser un test d'attaque depuis Kali car Ubuntu ne dispose pas de tous les outils

Valider qu'un pare-feu bien configuré limite très fortement les capacités d'un attaquant